Universidad Nacional de Ingeniería

Área de Conocimiento de Tecnología de la Información y Comunicación

ASIGNATURA: AUDITORIA DE SISTEMAS

Líder en Ciencia y Tecnología

Abril 2026

Carrera:

Ingeniería de Sistemas

Programa de asignatura/componente

CASO PRACTICO EN UNA EMPRESA

Clase practica

Elaborado por: Gerson Antonio Valdivia 2013-61725
Haxell Trejos Rodriguez 2011-39659
Stephanie Lucia Mora Chavez 2018-0261S
Alisson Michell Navarro Goussén 2016-0470U
Arleth del Rosario Velásquez Gómez 2019-3036S

Fecha de elaboración:

11/04/2026

CLASE PRACTICA NO.4

Objetivo: Aplicar los conocimientos adquiridos durante el desarrollo de la clase, para realizar auditoria en una empresa privada.

Descripción: Según sus equipos de trabajo de máximo 5 estudiantes, deben revisar la documentación y planteamientos, para que posteriormente apliquen estos conceptos y pasos en una empresa real.

Orientaciones del caso:

Caso Práctico: Auditoría Informática en "TechCommerce S.A."

1. Descripción de la Empresa

TechCommerce S.A. es una empresa de comercio electrónico con operaciones en varios países de Latinoamérica. Su plataforma web permite la compra y venta de productos electrónicos, procesando miles de transacciones diarias.

La empresa enfrenta problemas de seguridad, rendimiento y cumplimiento normativo, por lo que se ha solicitado una auditoría integral de los sistemas informáticos.

2. Objetivos de la Auditoría

- Evaluar la seguridad de la infraestructura tecnológica.
- Identificar vulnerabilidades en la red y los sistemas.
- Verificar la integridad y eficiencia de la base de datos.
- Asegurar el cumplimiento de normativas como **ISO 27001, PCI-DSS y GDPR**.
- Presentar recomendaciones y mejoras tecnológicas.

3. Alcance de la Auditoría

La auditoría se centrará en cuatro áreas críticas:

A. Sistemas de Información

- Análisis de los procesos internos soportados por TI.
- Evaluación del sistema de gestión de pedidos y CRM.
- Pruebas de integridad y disponibilidad de datos en el e-commerce.

B. Redes y Comunicaciones

- Auditoría de la infraestructura de red (firewalls, switches, VPNs).
- Identificación de posibles puntos de acceso no autorizados.
- Pruebas de rendimiento y disponibilidad del servidor web.

C. Base de Datos

- Revisión de la estructura y diseño de la base de datos SQL.
- Evaluación de la eficiencia en consultas y optimización de índices.
- Validación de los mecanismos de respaldo y recuperación de datos.

D. Seguridad Informática

- Pruebas de penetración (pentesting) en la aplicación web.
- Auditoría de accesos y privilegios en servidores y sistemas críticos.
- Evaluación del cumplimiento de normativas de protección de datos.
- Revisión de estrategias de backup y planes de contingencia.

4. Metodología

1. **Recopilación de información:** Entrevistas con el equipo de TI y análisis de documentación.
2. **Ejecución de pruebas técnicas:** Uso de herramientas como **Wireshark, Nmap, SQLmap, Nessus**.
3. **Identificación de riesgos:** Evaluación de amenazas y su impacto en el negocio.
4. **Generación del informe:** Informe con hallazgos, recomendaciones y plan de acción.

5. Resultados Esperados

- Detección de fallos críticos en seguridad y rendimiento.
- Implementación de mejoras en la infraestructura de red y base de datos.
- Capacitación del personal en buenas prácticas de ciberseguridad.
- Aseguramiento del cumplimiento con normativas y protección de datos.

6. Conclusiones

La auditoría permitirá a **TechCommerce S.A.** mejorar la seguridad y eficiencia de su plataforma, reduciendo riesgos operativos y fortaleciendo la confianza de sus clientes.

Asignación:

En base a lo anterior, presente un resumen de los resultados o productos de auditoría, si aplica todos esos elementos en su proyecto.

1. Fase I: Recopilación de Información y Planeación

1.1 Análisis de Contexto

Tras simular la solicitud de información al área de TI de TechCommerce S.A., se identificó la siguiente situación hipotética previa a las pruebas técnicas:

- Sistema de Gestión de Pedidos: Se utiliza un desarrollo interno sobre PHP 7.4 (Versión End-of-Life desde 2022) con base de datos MySQL 5.7.
- Infraestructura: Servidor Web Apache alojado en un VPS en la nube sin WAF (Web Application Firewall) activo. Firewall perimetral configurado con reglas por defecto.
- Cumplimiento: La empresa procesa pagos con tarjeta de crédito pero no ha completado el SAQ (Self-Assessment Questionnaire) de PCI-DSS correspondiente a este año.
- Backups: Se realizan backups completos semanales, pero no se realizan pruebas de restauración periódicas.

2. Fase II: Ejecución de Pruebas Técnicas

A continuación, se detallan los hallazgos clave simulados por el equipo de auditoría aplicando las herramientas mencionadas en la metodología.

Área Auditada	Herramienta Aplicada	Hallazgo Crítico Identificado	Riesgo Asociado
A. Sistemas de Información	Revisión de Logs / Análisis de Procesos	Falta de segregación de funciones: Los desarrolladores tienen acceso de escritura directo a la base de datos de producción para resolver incidencias.	Integridad de Datos: Riesgo alto de alteración o borrado accidental de transacciones financieras.
B. Redes y Comunicacione s	Nmap / Wireshark	Puerto RDP (3389) abierto a Internet para administración remota sin restricción de IP origen.	Acceso No Autorizado: Vulnerabilidad crítica a ataques de fuerza bruta (Brute Force).
C. Base de Datos	SQLmap / Análisis de Índices	Consulta No Parametrizada en barra de búsqueda: La función de búsqueda de productos es vulnerable a Inyección SQL (SQLi) .	Confidencialidad: Extracci ón total de la tabla de usuarios y contraseñas hasheadas.
D. Seguridad Informática	Nessus / Revisión de Cumplimient	Cifrado Débil en Tránsito: El portal de administración /admin perm	Cumplimiento / Seguridad: Exposición de credenciales de

Área Auditada	Herramienta Aplicada	Hallazgo Crítico Identificado	Riesgo Asociado
	o	ite conexión sin HTTPS forzado. Cumplimiento PCI-DSS Req. 4.1 fallido.	administrador en red Wi-Fi pública.

3. Fase III: Identificación de Riesgos y Análisis de Impacto

Aplicando el enfoque de la clase, clasificamos los riesgos según su impacto en el negocio de e-commerce:

Riesgo 1: Vulnerabilidad de Inyección SQL en Búsqueda (Área C)

- Probabilidad: Alta (Explotable con herramientas básicas como SQLmap).
- Impacto: Catastrófico**.** Pérdida total de la base de datos de clientes, sanciones económicas por violación de GDPR/Ley de Protección de Datos Personales, y pérdida de reputación en Latinoamérica.

Riesgo 2: Acceso RDP Abierto (Área B)

- Probabilidad: Media-Alta (Objetivo común de escaneos masivos de bots).
- Impacto: Alto. Un atacante que obtenga acceso al servidor podría instalar Ransomware paralizando el comercio electrónico por días.

Riesgo 3: Incumplimiento PCI-DSS (Área D)

- Probabilidad: Alta (Evidencia documental clara).
- Impacto: Financiero. Multas por parte de los procesadores de pago (Visa/Mastercard) y posible retiro de la licencia para operar con tarjetas de crédito.

4. Plan de Acción y Recomendaciones

En base a los hallazgos, el equipo propone el siguiente Plan de Remediación Priorizado:

Prioridad	Acción Recomendada	Área Responsable	Plazo Sugerido
CRÍTICA (24h)	Implementar WAF (Web Application Firewall) para bloquear intentos de SQLi mientras se parchea el código.	Seguridad / Desarrollo	Inmediato
ALTA (48h)	Restringir Puerto 3389 (RDP) mediante lista blanca de IPs estáticas del personal de TI o implementar VPN corporativa obligatoria.	Redes	48 horas
MEDIA (1 Semana)	Parchear código fuente: Modificar el input de búsqueda en PHP para usar Consultas Preparadas (Prepared Statements) .	Desarrollo	5 días hábiles
MEDIA (2 Semanas)	Forzar HTTPS en todo el dominio e implementar cabeceras HSTS (HTTP Strict Transport Security).	Sistemas	10 días
BAJA (1 Mes)	Establecer Procedimiento de Pruebas de Restauración de Backup trimestral.	Infraestructura	30 días

5. Conclusiones del Equipo de Auditoría

La auditoría practicada sobre el entorno de TechCommerce S.A. revela una brecha significativa entre la operación comercial ágil de un e-commerce y la madurez de su gobierno de seguridad informática.

1. **Conclusión Técnica:** La presencia de una vulnerabilidad de Inyección SQL en un sistema que maneja datos de tarjetas de crédito (aunque tokenizados) constituye un HALLAZGO CRÍTICO NIVEL 1 según estándares ISO 27001. La exposición del puerto RDP confirma una gestión de red reactiva y no proactiva.

2. **Conclusión de Cumplimiento:** TechCommerce S.A. NO cumple actualmente con el estándar PCI-DSS. Es imperativo detener nuevas integraciones de pago hasta subsanar el cifrado en tránsito y la vulnerabilidad de código.

3. **Valor Agregado:** La implementación de las recomendaciones de este informe no solo mitigará los riesgos de ciberataques, sino que fortalecerá la confianza del consumidor latinoamericano y preparará a la empresa para una futura certificación formal ISO 27001.